

Индивидуальный проект № 4: Использование Nikto

Эйвази Мани

6.октябрь.2026

Содержание

1	Цели и задачи работы	2
1.1	Цель лабораторной работы	2
1.2	Задачи	2
2	Теоретические сведения	3
2.1	Что ищет Nikto	3
2.2	Важные особенности	3
2.3	Ключевые параметры команды	3
3	Процесс выполнения лабораторной работы	5
3.1	Шаг 1. Проверка установки Nikto	5
3.2	Шаг 2. Первый запуск сканирования	5
3.3	Шаг 3. Анализ обнаруженных проблем	6
3.3.1	1. Отсутствует заголовок Strict-Transport-Security	6
3.3.2	2. Отсутствует заголовок X-Content-Type-Options	6
3.3.3	3. Отсутствует заголовок Permissions-Policy	6
3.3.4	4. Отсутствует заголовок Content-Security-Policy	6
3.3.5	5. Отсутствует заголовок Referrer-Policy	7
3.3.6	6. Обнаружена страница входа в систему	7
3.3.7	7. Устаревший заголовок X-Frame-Options	7
3.3.8	8. Не задан заголовок Content-Type	7
3.4	Шаг 4. Сохранение отчёта в формате HTML	8
3.5	Шаг 5. Просмотр сформированного отчёта	9
3.6	Шаг 6. Детализация обнаруженных проблем в отчёте	9

4	Результат работы Nikto	11
4.1	Общая статистика	11
4.2	Обнаруженные проблемы	11
4.3	Интерпретация результатов	11
4.4	Практическая ценность	12
5	Вывод	13

1 Цели и задачи работы

1.1 Цель лабораторной работы

Изучить принцип работы сканера безопасности веб-серверов **Nikto** и применить его для сканирования уязвимого веб-приложения DVWA, развёрнутого в локальной среде Kali Linux, с целью выявления типовых проблем конфигурации веб-сервера.

1.2 Задачи

1. Ознакомиться с назначением, возможностями и синтаксисом Nikto.
2. Выполнить базовое сканирование целевого веб-сервера с указанием порта.
3. Проанализировать обнаруженные уязвимости и предупреждения.
4. Сохранить отчёт о сканировании в формате HTML.
5. Изучить структуру сформированного отчёта и интерпретировать его содержимое.

2 Теоретические сведения

Nikto — это базовый сканер безопасности веб-сервера с открытым исходным кодом. Он выполняет комплексное тестирование веб-сервера и обнаруживает потенциально опасные файлы и скрипты, устаревшие версии серверного ПО, а также проблемы конфигурации, которые могут быть использованы злоумышленником.

2.1 Что ищет Nikto

Nikto способен обнаруживать следующие категории проблем:

Категория	Примеры
Опасные файлы	Резервные копии, тестовые страницы, файлы конфигурации, доступные извне
Устаревшее ПО	Старые версии Apache, nginx, PHP, CMS
Неправильная конфигурация	Отсутствующие заголовки безопасности, открытые листинги директорий
Раскрытие информации	Полные пути, баннеры сервера, сигнатуры технологий
Учётные данные	Страницы входа с возможностью подбора пароля

2.2 Важные особенности

- Nikto работает по **сигнатурному** принципу: он сверяет ответы сервера с базой известных шаблонов.
- Это **не эксплуатационный** инструмент — он только сообщает о потенциальных проблемах, не пытаясь их использовать.
- Сканирование может быть **замечено** системами обнаружения вторжений, поэтому в реальных условиях требует осторожности.
- Результаты носят **информационный характер** и требуют ручной проверки для подтверждения уязвимости.

2.3 Ключевые параметры команды

Параметр	Назначение
-h <host>	Целевой хост или IP-адрес
-p <port>	Порт веб-сервера (по умолчанию 80)
-o <file>	Файл для сохранения отчёта
-Format <type>	Формат отчёта (htm, csv, txt, xml и др.)
-ssl	Использовать SSL/TLS
-Tuning <n>	Выбор типов проверок (например, -Tuning 123 — только определённые категории)
-Display <n>	Управление выводом (например, -Display V — показывать только найденное)

3 Процесс выполнения лабораторной работы

3.1 Шаг 1. Проверка установки Nikto

Перед началом работы убеждаемся, что Nikto установлен в системе. Переходим в директорию плагинов и запускаем проверку версии командой:

```
cd /var/lib/nikto/plugins
nikto -Version
```

В выводе отображается версия **Nikto v2.6.0**, что подтверждает корректную установку инструмента.

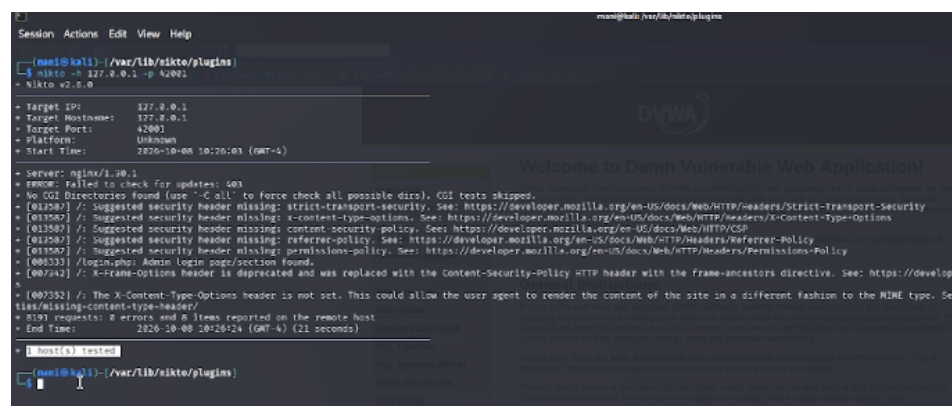


Рис. 1 — Проверка версии Nikto

3.2 Шаг 2. Первый запуск сканирования

Выполняем сканирование локального веб-сервера DVWA с указанием порта **42001**, на котором работает приложение:

```
nikto -h 127.0.0.1 -p 42001
```

Nikto выводит информацию о целевом хосте:

- **Target IP:** 127.0.0.1
- **Target Hostname:** 127.0.0.1
- **Target Port:** 42001
- **Platform:** Unknown
- **Server:** nginx/1.30.1

3.3.5 5. Отсутствует заголовок Referrer-Policy

+ /: Suggested security header missing: referrer-policy.

Заголовок **Referrer-Policy** контролирует, какая информация о текущей странице передаётся в заголовке Referer при переходе на другие сайты.

3.3.6 6. Обнаружена страница входа в систему

+ /login.php: Admin login page/section found.

Nikto обнаружил страницу login.php — форму входа администратора. Это ожидаемо для DVWA и показывает, что сканер корректно распознаёт точки аутентификации.

3.3.7 7. Устаревший заголовок X-Frame-Options

+ /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive.

Заголовок X-Frame-Options считался стандартом для защиты от clickjacking, но сейчас он **устарел** в пользу директивы frame-ancestors в CSP.

3.3.8 8. Не задан заголовок Content-Type

+ /: The X-Content-Type-Options header is not set. This could allow the user agent to display the content of the site in a different fashion to the MIME type.

Отсутствие явного указания Content-Type позволяет браузеру самостоятельно определять тип содержимого, что открывает путь к атакам через MIME-confusion.

127.0.0.1 / 127.0.0.1 port 42001	
Target IP	127.0.0.1
Target hostname	127.0.0.1
Target Port	42001
HTTP Server	nginx/1.30.1
Site Link (Name)	http://127.0.0.1:42001/
Site Link (IP)	http://127.0.0.1:42001/
URI	/
HTTP Method	GET
Description	/: Suggested security header missing: strict-transport-security.
Link	http://127.0.0.1:42001/
Reference(s)	https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
URI	/
HTTP Method	GET
Description	/: Suggested security header missing: x-content-type-options.
Link	http://127.0.0.1:42001/
Reference(s)	https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
URI	/
HTTP Method	GET
Description	/: Suggested security header missing: permissions-policy.
Link	http://127.0.0.1:42001/
Reference(s)	https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
URI	/
HTTP Method	GET
Description	/: Suggested security header missing: content-security-policy.
Link	http://127.0.0.1:42001/
Reference(s)	https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
URI	/
HTTP Method	GET
Description	/: Suggested security header missing: referrer-policy.
Link	http://127.0.0.1:42001/

Рис. 3 — Список обнаруженных Nikto проблем

3.4 Шаг 4. Сохранение отчёта в формате HTML

Для формирования итогового отчёта повторно запускаем сканирование с сохранением результатов в файл:

```
nikto -h 127.0.0.1 -p 42001 -o /home/mani/nikto_dvwa_report.html -Format htm
```

Параметры команды:

- `-h 127.0.0.1` — целевой хост (локальный);
- `-p 42001` — порт, на котором работает DVWA;
- `-o /home/mani/nikto_dvwa_report.html` — путь для сохранения отчёта;
- `-Format htm` — формат отчёта HTML.

После завершения сканирования в терминале отображается сообщение:

```
+ 8191 requests: 0 error(s) and 8 item(s) reported on remote host
+ End Time: 2026-10-08 10:27:13 (GMT-4) (23 seconds)
```

Это означает, что Nikto выполнил **8191 запрос** к серверу, не встретил ошибок и обнаружил **8 проблем**.

Host Summary	
Start Time	2026-10-08 10:26:50
End Time	2026-10-08 10:27:13
Elapsed Time	23 seconds
Statistics	8191 requests, 0 errors, 8 findings

Scan Summary	
Software Details	Nikto 2.6.0
CLI Options	-h 127.0.0.1 -p 42001 -o /home/mani/nikto_dvwa_report.html -Format html
Hosts Tested	1
Start Time	Thu Oct 8 10:26:50 2026
End Time	Thu Oct 8 10:27:13 2026
Elapsed Time	23 seconds

© 2008 Chris Sullo

Рис. 4 — Сохранение отчёта Nikto в HTML

3.5 Шаг 5. Просмотр сформированного отчёта

Открываем созданный HTML-отчёт в браузере:

```
firefox /home/mani/nikto_dvwa_report.html
```

В отчёте отображается структурированная информация о сканировании. В верхней части — **Host Summary** и **Scan Summary** с ключевыми метриками:

- **Start Time:** 2026-10-08 10:26:50
- **End Time:** 2026-10-08 10:27:13
- **Elapsed Time:** 23 seconds
- **Statistics:** 8191 requests, 0 errors, 8 findings
- **Software Details:** Nikto 2.6.0
- **CLI Options:** полная команда запуска
- **Hosts Tested:** 1

Рис. 5 — Сводка Host Summary и Scan Summary

3.6 Шаг 6. Детализация обнаруженных проблем в отчёте

В нижней части отчёта приведены подробные описания каждой находки. Для каждой проблемы указываются:

- **URI** — путь на сервере, где обнаружена проблема (в данном случае /);
- **HTTP Method** — метод запроса (GET);
- **Description** — описание проблемы;
- **Link** — ссылка на документацию (например, на MDN для соответствующих заголовков безопасности);
- **Reference(s)** — источники с дополнительной информацией.

Например, для отсутствующего заголовка Strict-Transport-Security в отчёте указана ссылка на официальную документацию Mozilla:

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security>

Рис. 6 — Детализация находок в HTML-отчёте

4 Результат работы Nikto

4.1 Общая статистика

Метрика	Значение
Целевой хост	127.0.0.1
Порт	42001
Версия сервера	nginx/1.30.1
Всего запросов	8191
Ошибок	0
Обнаружено проблем	8
Время сканирования	23

4.2 Обнаруженные проблемы

Все 8 обнаруженных проблем относятся к категории **отсутствующих или устаревших HTTP-заголовков безопасности**:

1. **Strict-Transport-Security** — не задан заголовок HSTS.
2. **X-Content-Type-Options** — не задан заголовок защиты от MIME-sniffing.
3. **Permissions-Policy** — не задана политика разрешений браузера.
4. **Content-Security-Policy** — не задана политика безопасности контента.
5. **Referrer-Policy** — не задана политика передачи referrer.
6. **Admin login page found** — обнаружена страница входа администратора (/login.php).
7. **X-Frame-Options** — устаревший заголовок, заменён на CSP frame-ancestors.
8. **Content-Type не задан** — риск MIME-confusion.

4.3 Интерпретация результатов

Важно понимать, что **отсутствие заголовков безопасности** — это не уязвимость сама по себе, а **ослабление защиты**. DVWA — намеренно уязвимое приложение, поэтому ожидаемо, что его конфигурация не включает защитные механизмы.

Однако в реальной эксплуатации веб-приложения такие находки требуют внимания:

- **Отсутствие HSTS** делает возможными атаки понижения протокола (SSL-stripping), особенно если сайт доступен и по HTTP, и по HTTPS.
- **Отсутствие CSP** означает, что XSS-атаки не блокируются на уровне браузера, что особенно опасно для приложений, работающих с пользовательскими

данными.

- **Отсутствие X-Content-Type-Options: nosniff** позволяет злоумышленнику загрузить файл, который браузер интерпретирует как исполняемый код, даже если сервер отдаёт его как изображение.
- **Отсутствие Referrer-Policy** может привести к утечке чувствительных данных (например, URL с токенами) на сторонние ресурсы.
- **Отсутствие Permissions-Policy** даёт возможность нежелательного доступа к функциям устройства пользователя.

4.4 Практическая ценность

Nikto продемонстрировал свою эффективность как инструмент **быстрой оценки конфигурации веб-сервера**. За 23 секунды сканирования он:

- Определил версию серверного ПО (nginx/1.30.1);
- Нашёл страницу административной аутентификации;
- Выявил 6 проблем с заголовками безопасности;
- Указал ссылки на документацию для каждой находки.

При этом Nikto не обнаружил **уязвимостей приложения** (SQL-инъекции, XSS, CSRF) — для этого требуются специализированные инструменты (Burp Suite, sqlmap, OWASP ZAP). Nikto дополняет их, обеспечивая проверку **серверного окружения и конфигурации**.

5 Вывод

В ходе индивидуального проекта № 4 был изучен и практически применён сканер безопасности веб-серверов **Nikto**. С его помощью выполнено сканирование уязвимого приложения DVWA, развёрнутого на порту 42001 локального сервера. Nikto выполнил **8191 HTTP-запросов** за 23 секунды, не встретив ошибок, и обнаружил **8 проблем**, связанных с отсутствием или устареванием HTTP-заголовков безопасности.

Освоены ключевые параметры команды Nikto:

- -h — целевой хост;
- -p — порт;
- -o — файл отчёта;
- -Format htm — формат сохранения результатов.

Полученный HTML-отчёт содержит структурированную информацию: сводку сканирования, статистику, детальное описание каждой находки со ссылками на документацию. Это делает Nikto удобным инструментом для быстрой первичной оценки защищённости веб-сервера и подготовки отчётов.

Основной вывод работы: **Nikto — эффективный инструмент для выявления проблем конфигурации веб-сервера**, однако он не заменяет специализированные сканеры уязвимостей приложений. Для комплексного аудита безопасности веб-приложения необходимо сочетать Nikto с инструментами динамического анализа (Burp Suite, OWASP ZAP) и ручным тестированием.